

MAPEO DETALLADO: PREGUNTAS GQM → REQUISITOS NORMATIVOS

OWASP SAMM v2 + Regulación (NIS2, CRA, GDPR, ENS, DORA)

Versión: 1.0 | **Fecha:** Enero 2026

Ámbito: Operadores esenciales e importantes españoles bajo NIS2, CRA, GDPR, ENS, DORA

Propósito: Trazabilidad explícita de cada pregunta de encuesta a artículos regulatorios

INTRODUCCIÓN

Este documento mapea cada pregunta GQM (identificada como Q-DOMINIO-N) derivada del marco OWASP SAMM v2 directamente a:

1. Artículos específicos de normativa (NIS2, CRA, GDPR, ENS, DORA)
2. Cómo contribuye la pregunta a demostrar cumplimiento
3. Métricas asociadas que la responden
4. Evidencias técnicas necesarias

TABLA 1: GOBERNANZA (GOV)

Q-GOV-1: Estrategia AppSec formalizada

Aspecto	Contenido
Pregunta	¿Existe documentada formalmente una estrategia plurianual de seguridad de software (AppSec) y está actualizada (< 12 meses)?
Métrica asociada	M-GOV-01: Strategy Documentation Score (0-3)
Normativa	NIS2 Art. 21.2(a): "políticas de análisis de riesgos y seguridad de sistemas de información"
Cómo contribuye	Demuestra que la organización tiene formalizada una política de seguridad de software integrada en su gestión de riesgos TIC
Normativa secundaria	CRA Annex I (diseño y desarrollo seguros); GDPR Art. 25 (privacy by design)
Evidencias técnicas	Documento de estrategia en repositorio corporativo (Wiki/SharePoint); fecha de última actualización; aprobación por comité
Periodicidad revisión	Anual o post-cambios regulatorios significativos

Q-GOV-2: Comunicación y revisión de estrategia

Aspecto	Contenido
Pregunta	¿Con qué frecuencia se revisa, aprueba y comunica la estrategia de AppSec a stakeholders clave (gobernanza, desarrollo, operaciones)?
Métrica asociada	M-GOV-02: Strategy Review Frequency (# sesiones/año); M-GOV-03: Stakeholder Awareness (%)
Normativa	NIS2 Art. 21.1 y 21.2: obligación de "medidas continuas y proporcionales"; Art. 20: gobernanza
Cómo contribuye	La revisión periódica evidencia que la organización mejora continuamente (criterio de proporcionalidad NIS2) y que existe alineación entre funciones
Normativa secundaria	ENS: revisión de marco organizativo; DORA: revisión de función de gestión de riesgos TIC
Evidencias técnicas	Calendario de reuniones; actas de revisión; lista de asistentes por rol; evidencia de comunicación (email, boletín, intranet)
Umbral cumplimiento	Mínimo 2-4 revisiones formales/año

Q-GOV-3: KPIs de seguridad de software

Aspecto	Contenido
Pregunta	¿Existen KPIs (Key Performance Indicators) definidos para medir éxito de la estrategia de AppSec? ¿Se rastrean y reportan mensualmente?
Métrica asociada	M-GOV-04: KPI Completeness (# de KPIs definidos); M-GOV-05: KPI Tracking Rate (% reportados)
Normativa	NIS2 Art. 21: medidas deben ser "evaluables" y "verificables"; implícito en concepto de governance
Cómo contribuye	La existencia de KPIs demuestra que se puede medir y evaluar la eficacia de las medidas de seguridad (requisito NIS2 implícito en Art. 20)
Normativa secundaria	CRA (art. 4): proveedores deben poder demostrar conformidad; DORA: gestión de riesgos debe ser medible
Evidencias técnicas	Dashboard o reporte mensual de KPIs (ej: % threat models documentados, MTDD, MTTR, etc.); propietario asignado
Umbral cumplimiento	Mínimo 5-7 KPIs; rastreados en >80% de meses

Q-GOV-4: Roles y responsabilidades

Aspecto	Contenido
Pregunta	¿Están claramente definidas y documentadas las responsabilidades de seguridad de software por rol (CISO, architects, developers, QA, ops)?
Métrica asociada	M-GOV-06: RACI Matrix Completeness; M-GOV-07: Role Clarity Score
Normativa	NIS2 Art. 20: "medidas de gobernanza" incluyen asignación clara de responsabilidades
Cómo contribuye	Estructura organizativa clara es requisito fundamental de gobernanza; facilita auditoría y accountability
Normativa secundaria	ENS (organización); GDPR Art. 32 (roles de DPO, security leads)
Evidencias técnicas	Matriz RACI documentada; organigrama con funciones de seguridad; job descriptions
Umbral cumplimiento	RACI completado; todos los roles clave identificados

TABLA 2: DISEÑO (DES)

Q-DES-1: Cobertura de threat modeling

Aspecto	Contenido
Pregunta	¿Qué porcentaje de aplicaciones críticas dispone de threat model documentado y actualizado (< 6 meses)?
Métrica asociada	M-DES-01: Threat Model Coverage (%)
Normativa	CRA Annex I, Clause 2.2: "identificación de amenazas y evaluación de riesgos" durante diseño
Cómo contribuye	Threat modeling sistemático es evidencia directa de cumplimiento CRA "Secure by Design" (Art. 10)
Normativa secundaria	NIS2 Art. 21.2(a): "análisis de riesgos" a nivel de aplicación; GDPR Art. 25 (privacy threats)
Evidencias técnicas	Threat model documents en repositorio (STRIDE, PASTA, etc.); fecha de creación/actualización; enlace a vulnerabilidades encontradas
Umbral cumplimiento	Mínimo 90% de apps críticas con threat model activo

Q-DES-2: Profundidad de threat modeling (STRIDE)

Aspecto	Contenido
Pregunta	¿Qué % de threat models cubre explícitamente todas las 6 categorías STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, DoS, Elevation)?
Métrica asociada	M-DES-02: STRIDE Coverage per Model (%)
Normativa	CRA: "All relevant threats" deben ser considerados (implícito en Secure by Design)
Cómo contribuye	Demuestra rigor metodológico y cobertura sistemática de amenazas; auditor puede verificar que no hay "gaps" obvios
Normativa secundaria	NIS2: rigor en análisis de riesgos
Evidencias técnicas	Documento de threat model con sección explícita por cada categoría STRIDE
Umbral cumplimiento	Mínimo 80% de modelos con todas 6 categorías analizadas

Q-DES-3: Vulnerabilidades de diseño pre-producción

Aspecto	Contenido
Pregunta	¿Cuántas vulnerabilidades de arquitectura/diseño se detectan y corrigen antes de pasar a producción (# absoluto y % de cierre pre-prod)?
Métrica asociada	M-DES-03: Arch Finding Resolution Time (días); M-DES-04: Pre-Prod Arch Closure Rate (%)
Normativa	CRA Art. 10: "productos sin vulnerabilidades explotables conocidas"; implicación: deben eliminarse en fase de diseño
Cómo contribuye	Muestra que la org encuentra y cierra fallos de diseño antes de exponerse a producción
Normativa secundaria	NIS2 Art. 21.2(a)(d): reducción de riesgos sistémicos; ENS: medidas de protección
Evidencias técnicas	Logs de hallazgos de revisión arquitectónica; cierre de tickets antes de release a prod
Umbral cumplimiento	Mínimo 95% de hallazgos críticos cerrados pre-prod

TABLA 3: IMPLEMENTACIÓN (IMP)

Q-IMP-1: SAST en CI/CD

Aspecto	Contenido
Pregunta	¿Qué % de aplicaciones tiene SAST (Static Application Security Testing) integrado en la cadena de CI/CD con política de bloqueo automático ("gates") para vulnerabilidades críticas?
Métrica asociada	M-IMP-01: SAST Integration Coverage (%); M-IMP-02: Build Gate Block Rate (%)
Normativa	CRA Annex I: "análisis de seguridad automático" del código; NIS2 Art. 21.2(a)(g): "ciberhigiene básica"
Cómo contribuye	SAST en CI/CD es control automático que detecta vulnerabilidades comunes antes de que lleguen a producción
Normativa secundaria	DORA: gestión de riesgos en ciclo de vida de software
Evidencias técnicas	Configuración de CI/CD (Jenkins/GitLab/GitHub Actions) mostrando SAST activado; logs de ejecución; umbral de bloqueo definido
Umbral cumplimiento	Mínimo 95% apps críticas con SAST en CI/CD; gate configurado

Q-IMP-2: Componentes de terceros (SCA)

Aspecto	Contenido
Pregunta	¿Qué % de builds ejecuta análisis de composición (SCA) para detectar vulnerabilidades en librerías de terceros?
Métrica asociada	M-IMP-03: SCA Integration Coverage (%); M-IMP-04: Vulnerable Component Detection Rate (%)
Normativa	CRA Annex I, Clause 2.2(iv): gestión de riesgos en componentes de terceros; NIS2 Art. 21: supply chain security (implícito)
Cómo contribuye	Evidencia de control de la cadena de suministro software; muestra awareness de vulnerabilidades transitivas
Normativa secundaria	NIST CSF (SC-4), ISO 27001 (A.14.2.5)
Evidencias técnicas	SCA tool configurado (OWASP Dependency-Check, Snyk, etc.); reportes de vulns detectadas; política de actualización
Umbral cumplimiento	Mínimo 90% builds con SCA; vulns críticas bloqueadas

Q-IMP-3: Cierre pre-producción

Aspecto	Contenido
Pregunta	¿Qué % de vulnerabilidades identificadas por SAST/SCA se corrige antes del despliegue a producción?
Métrica asociada	M-IMP-05: Pre-Prod Vulnerability Closure Rate (%)
Normativa	CRA Art. 10 (producto sin vulns explotables); NIS2 Art. 21.2(a)(d): gestión de vulnerabilidades
Cómo contribuye	Métrica clave de conformidad CRA: demuestra que la org no despliega vulnerabilidades conocidas
Normativa secundaria	GDPR Art. 32 (medidas técnicas adecuadas)
Evidencias técnicas	Correlación entre hallazgos de SAST/SCA y cierre de tickets en DEF tracker antes de release
Umbral cumplimiento	Mínimo 98% de críticas; 95% de altas cerradas pre-prod

Q-IMP-4: Secrets management

Aspecto	Contenido
Pregunta	¿Dispone la organización de un sistema de gestión de secretos (API keys, DB passwords, certs) que previene su hardcoding en código?
Métrica asociada	M-IMP-06: Secrets Management Coverage (%); M-IMP-07: Secret Detection Rate (detecciones de scanner)
Normativa	NIS2 Art. 21.2(a)(g): ciberhigiene (gestión de credenciales); GDPR Art. 32
Cómo contribuye	Control operacional que reduce exposición de credenciales en repositorios públicos/privados
Normativa secundaria	CRA: best practices de desarrollo seguro
Evidencias técnicas	Vault / Azure KeyVault / AWS Secrets Manager / similar configurado; políticas de CI/CD que bloquean secrets en código
Umbral cumplimiento	Mínimo 100% de apps usando secrets manager; 0 secrets detectadas en repos

TABLA 4: VERIFICACIÓN (VER)

Q-VER-1: Cobertura de pruebas de seguridad

Aspecto	Contenido
Pregunta	¿Qué % de requisitos de seguridad cuentan con casos de prueba (test cases) documentados y ejecutados regularmente?
Métrica asociada	M-VER-01: Security Test Coverage (%); M-VER-02: Test Execution Rate (%)
Normativa	CRA Annex I: "pruebas de conformidad"; NIS2 Art. 21: "pruebas" de eficacia de medidas
Cómo contribuye	Demuestra que se verifica sistemáticamente que los requisitos de seguridad se cumplen
Normativa secundaria	ISO 27001 A.14.2.8 (testing)
Evidencias técnicas	Test repository (Jira, TestRail, etc.) con mapeo de test case a requisito de seguridad; resultados de ejecución
Umbral cumplimiento	Mínimo 85% cobertura; >95% de tests ejecutados por release

Q-VER-2: DAST (Dynamic Testing)

Aspecto	Contenido
Pregunta	¿Se ejecutan pruebas dinámicas (DAST) contra aplicaciones web/móviles en ambiente de staging antes de producción? ¿Con qué frecuencia?
Métrica asociada	M-VER-03: DAST Execution Frequency (# al año); M-VER-04: DAST Finding Closure (%)
Normativa	CRA: "evaluación de seguridad" antes de release; NIS2: pruebas de resiliencia
Cómo contribuye	DAST captura vulnerabilidades runtime (inyecciones, lógica, autenticación) que SAST no detecta
Normativa secundaria	OWASP Top 10; ISO 27001 A.14.2.8
Evidencias técnicas	DAST tool ejecutado (Burp, OWASP ZAP, etc.); reportes de vuln por release; SLA de cierre
Umbral cumplimiento	Mínimo 1 DAST pre-release por app crítica; >90% hallazgos cerrados

Q-VER-3: Penetration Testing

Aspecto	Contenido
Pregunta	¿Cuántos pentests (pruebas de penetración) se realizan anualmente a sistemas/apps críticos? ¿Qué % de hallazgos críticos se cierra?
Métrica asociada	M-VER-05: Pentest Frequency (# al año); M-VER-06: Pentest Finding Closure (%)
Normativa	NIS2 Art. 21: "ejercicios" de evaluación de ciberseguridad; CRA: evaluación integral de seguridad
Cómo contribuye	Pentest es validación "holística" de seguridad (combina técnica + negocio + procesos); auditor lo valora como "gold standard"
Normativa secundaria	DORA: pruebas avanzadas de resiliencia; NIST CSF (RS.IM-2)
Evidencias técnicas	Reportes de pentest; contrato con proveedor; plan de cierre de hallazgos
Umbral cumplimiento	Mínimo 1-2 pentests/año para apps críticas; 100% hallazgos críticos cerrados

Q-VER-4: Red teaming o ejercicios simulados

Aspecto	Contenido
Pregunta	¿Realiza la organización ejercicios de simulación (red team, tabletop) para evaluar respuesta ante incidentes?
Métrica asociada	M-VER-07: Red Team Exercise Frequency (# al año); M-VER-08: Exercise Effectiveness Score
Normativa	NIS2 Art. 21: "ejercicios de gestión de incidentes"; DORA: pruebas de resiliencia
Cómo contribuye	Demuestra que la organización entrena reacción ante incidentes (no solo prevención); importante para DORA y resiliencia operacional
Normativa secundaria	NIST CSF (RS.CO-3)
Evidencias técnicas	Plan anual de ejercicios; reportes post-ejercicio; acciones correctivas identificadas
Umbral cumplimiento	Mínimo 1-2 ejercicios/año; >60% participación de SOC/ops

TABLA 5: OPERACIONES (OPS)

Q-OPS-1: MTDD (Mean Time To Detect)

Aspecto	Contenido
Pregunta	¿Cuál es el MTDD promedio (horas) desde que ocurre un incidente hasta que se detecta? ¿Cuál es la mediana y percentil 95?
Métrica asociada	M-OPS-01: MTDD Mean; M-OPS-02: MTDD Median; M-OPS-03: MTDD P95
Normativa	NIS2 Art. 21.2(b)(c): obligación de detectar y responder a incidentes; Art. 23: notificar dentro de 72h
Cómo contribuye	MTDD es métrica operacional clave: cuanto menor, menor exposición. Es precursor del MTTR y de la severidad final del incidente
Normativa secundaria	DORA: resiliencia operacional; CRA (implícito en gestión de incidentes)
Evidencias técnicas	Logs de SIEM/SOC con timestamps de occurrence y detection; análisis de correlación de eventos
Umbral cumplimiento	MTDD < 4h para críticos; < 24h para altos (goal NIS2 implícito)

Q-OPS-2: MTTR (Mean Time To Remediate)

Aspecto	Contenido
Pregunta	¿Cuál es el MTTR promedio (horas) desde detección hasta cierre de vulnerabilidad/incidente? Desglosado por severidad (crítica, alta, media)
Métrica asociada	M-OPS-04: MTTR Critical; M-OPS-05: MTTR High; M-OPS-06: MTTR Compliance (% dentro SLA)
Normativa	NIS2 Art. 21.2(a)(d): gestión de vulnerabilidades; CRA Art. 10: remediación "sin demora"
Cómo contribuye	MTTR demuestra velocidad de respuesta operativa; es indicador directo de eficacia en reducir exposición
Normativa secundaria	DORA: capacidad de recuperación
Evidencias técnicas	Incident tracking system con SLAs definidos; cierre de tickets; logs de remediación
Umbral cumplimiento	MTTR Critical < 24h; High < 7 días; Compliance > 95%

Q-OPS-3: Patch Compliance

Aspecto	Contenido
Pregunta	¿Qué % de sistemas críticos se parchean dentro del SLA definido (ej: 24h para crítica, 7 días para alta)?
Métrica asociada	M-OPS-07: Patch Compliance Critical (%); M-OPS-08: Patch Compliance High (%); M-OPS-09: Patch Lag Days
Normativa	NIS2 Art. 21.2(a)(g): ciberhigiene básica (patching); CRA: remediación de vulnerabilidades
Cómo contribuye	Patch compliance es medida preventiva de exposición; demuestra diligencia operacional
Normativa secundaria	ENS: medidas de protección; ISO 27001 A.12.6.1
Evidencias técnicas	Patch management tool (WSUS, Jamf, etc.); reportes de cumplimiento; análisis de gaps
Umbral cumplimiento	Mínimo 95% críticos en 24h; 90% altos en 7 días

Q-OPS-4: Incident Handling Capability

Aspecto	Contenido
Pregunta	¿Existe un plan de incident response documentado? ¿Se ejecuta regularmente? ¿Hay análisis post-incidente?
Métrica asociada	M-OPS-10: IR Plan Completeness; M-OPS-11: IR Exercise Frequency; M-OPS-12: Post-Incident Review Rate (%)
Normativa	NIS2 Art. 21.2(b)(c): procedimientos de gestión de incidentes; Art. 23: notificación
Cómo contribuye	Demuestra que la organización tiene procesos documentados y probados para responder a incidentes
Normativa secundaria	GDPR Art. 33; DORA Art. 17
Evidencias técnicas	Documento de IR plan; evidencia de ejercicios; registros de post-mortems
Umbral cumplimiento	Plan documentado; ≥1 ejercicio/año; post-mortems en >90% de incidentes críticos

TABLA 6: GESTIÓN DE VULNERABILIDADES (VULN)

Q-VULN-1: Cobertura de escaneo

Aspecto	Contenido
Pregunta	¿Qué % de sistemas/aplicaciones se escanean en busca de vulnerabilidades cada mes? ¿Con qué frecuencia?
Métrica asociada	M-VULN-01: Scan Coverage (%); M-VULN-02: Scan Frequency (escaneos/año)
Normativa	NIS2 Art. 21.2(a)(d): identificación y gestión de vulnerabilidades
Cómo contribuye	Cobertura de escaneo es línea base de visibilidad de vulnerabilidades
Normativa secundaria	CRA (implicit); ENS: evaluación de vulnerabilidades
Evidencias técnicas	Logs de scanner (Nessus, Qualys, etc.); inventario de activos escaneados
Umbral cumplimiento	Mínimo 90% cobertura; semanal o superior para críticos

Q-VULN-2: Priorización de vulnerabilidades

Aspecto	Contenido
Pregunta	¿Cómo se priorizan las vulnerabilidades? ¿Se usa CVSS, EPSS, contexto de negocio, o solo CVSS?
Métrica asociada	M-VULN-03: Prioritization Sophistication (1-5); M-VULN-04: EPSS Coverage (%)
Normativa	NIS2 Art. 21: medidas deben ser "proporcionales" al riesgo; implica priorización racional
Cómo contribuye	Priorización sofisticada evita perder recursos en falsos positivos y enfoca en vulns explotables reales
Normativa secundaria	CRA: "known exploitable"; NIST CSF (risk-based)
Evidencias técnicas	Política de priorización documentada; uso de herramientas EPSS (FIRST.org); lista de priorización con contexto
Umbral cumplimiento	Mínimo nivel 3 (CVSS + contexto); idealmente nivel 4 (EPSS)

Q-VULN-3: Cierre de vulnerabilidades críticas

Aspecto	Contenido
Pregunta	¿Qué % de vulnerabilidades críticas/CVSS > 8.0 se cierra dentro del SLA (ej: 30 días)?
Métrica asociada	M-VULN-05: Critical Vuln Closure Rate (%); M-VULN-06: Critical Vuln Closure Time (días)
Normativa	NIS2 Art. 21.2(a)(d): "gestión de vulnerabilidades"; CRA Art. 10: sin vulns explotables conocidas
Cómo contribuye	Demuestra que la organización efectivamente cierra vulnerabilidades críticas, reduciendo exposición material
Normativa secundaria	ISO 27001 A.12.6.1; DORA: resiliencia
Evidencias técnicas	Correlation entre reportes de scan y cierre de tickets; SLA definido y monitorizado
Umbral cumplimiento	Mínimo 95% cerradas dentro de 30 días

TABLA 7: SIEM Y MONITOREO (SIEM)

Q-SIEM-1: Cobertura de fuentes de datos

Aspecto	Contenido
Pregunta	¿Qué % de tipos de fuentes de datos definidas en la arquitectura SIEM están activamente enviando logs?
Métrica asociada	M-SIEM-01: Data Source Coverage (%); M-SIEM-02: Log Volume Daily (GB); M-SIEM-03: Data Availability Uptime (%)
Normativa	NIS2 Art. 21.2(b): logging y monitorización; Art. 23: incident notification
Cómo contribuye	Cobertura de fuentes SIEM es prerequisite para detección efectiva (no puedes detectar lo que no ves)
Normativa secundaria	ENS: registro de eventos; DORA: monitorización continua
Evidencias técnicas	SIEM inventory; estado de colectores; test de datos por fuente
Umbral cumplimiento	Mínimo 95% fuentes en línea; >99% uptime SIEM

Q-SIEM-2: Calidad de alertas (False Positive Rate)

Aspecto	Contenido
Pregunta	¿Cuál es la tasa de falsos positivos (% de alertas que no son verdaderos incidentes) en el SIEM?
Métrica asociada	M-SIEM-04: False Positive Rate (%); M-SIEM-05: Alert to Incident Conversion (%)
Normativa	NIS2 Art. 21: medidas deben ser "eficaces"; FP rate alto significa ineficacia
Cómo contribuye	FP rate bajo indica reglas de detección bien ajustadas y SOC efectivo
Normativa secundaria	DORA: capacidad de detección
Evidencias técnicas	Análisis de alertas del último mes; clasificación FP vs TP; trending
Umbral cumplimiento	Máximo 40-50% FP (benchmark global); objetivo < 30%

Q-SIEM-3: Timeliness de detección

Aspecto	Contenido
Pregunta	¿Cuál es el tiempo promedio (segundos/minutos) entre que ocurre un evento y se genera una alerta en SIEM?
Métrica asociada	M-SIEM-06: Alert Generation Latency (segundos); M-SIEM-07: Alert Delivery SLA Compliance (%)
Normativa	NIS2 Art. 21: detección rápida es implícito en "incident response"; Art. 23: 72h para notificación
Cómo contribuye	Latencia baja en alertas es crítica para MTTR; cada segundo cuenta
Normativa secundaria	DORA: capacidad de respuesta
Evidencias técnicas	SIEM performance metrics; test de eventos artificiales; análisis de lag en correlación
Umbral cumplimiento	Máximo 5 minutos para correlación; < 1 segundo para alertas simples

TABLA 8: CAPACITACIÓN Y CONCIENCIA (TRAIN)

Q-TRAIN-1: Cobertura de formación anual

Aspecto	Contenido
Pregunta	¿Qué % de empleados completó formación de ciberseguridad obligatoria en el último año?
Métrica asociada	M-TRAIN-01: Training Completion Rate (%); M-TRAIN-02: Training Hours per Capita (horas/empleado)
Normativa	NIS2 Art. 21.2(g): "sensibilización y formación en ciberseguridad"; GDPR Art. 32
Cómo contribuye	Métrica de cumplimiento formal de obligación regulatoria
Normativa secundaria	ENS: formación en seguridad; ISO 27001 A.7.3.1
Evidencias técnicas	LMS (Learning Management System) con registro de completados; certificados de curso
Umbral cumplimiento	Mínimo 90-95% completados; idealmente 100%; mínimo 4-8 horas/año

Q-TRAIN-2: Comportamiento ante phishing

Aspecto	Contenido
Pregunta	¿Cuál es la tasa de clic en simulaciones de phishing (% de empleados que clickean en correos de prueba)?
Métrica asociada	M-TRAIN-03: Phishing Click Rate (%); M-TRAIN-04: Report Rate (%); M-TRAIN-05: Time to Report (minutos)
Normativa	NIS2 Art. 21.2(g): formación efectiva (no solo asistencia); GDPR Art. 32
Cómo contribuye	Mide eficacia real de formación en cambio de comportamiento (no solo cumplimiento formal)
Normativa secundaria	Prevención de ataques de ingeniería social; DORA: reducción de riesgo humano
Evidencias técnicas	Plataforma de simulación phishing (Gophish, Knowbe4, etc.); reportes mensuales
Umbral cumplimiento	< 5% click rate (goal); > 60% report rate; < 10 min promedio reporte

Q-TRAIN-3: Segmentación de formación por rol

Aspecto	Contenido
Pregunta	¿Existe formación diferenciada por rol (developers, testers, ops, ejecutivos, usuarios generales)?
Métrica asociada	M-TRAIN-06: Role-based Training Coverage (%); M-TRAIN-07: Role-specific Content Quality
Normativa	NIS2 Art. 21.2(g): formación "apropiada" (implica segmentación); GDPR Art. 32
Cómo contribuye	Formación diferenciada es más eficaz; demuestra rigor pedagógico
Normativa secundaria	ISO 27001 A.7.3.2
Evidencias técnicas	Curriculum diferenciado en LMS; contenido específico por rol; métricas de aprendizaje por grupo
Umbral cumplimiento	Mínimo 3-4 vías: básica, desarrolladores, operaciones, ejecutivos

Q-TRAIN-4: Entrenamientos post-incidente

Aspecto	Contenido
Pregunta	Cuando ocurre un incidente (ej: éxito de phishing, malware), ¿se realiza formación correctiva a empleados afectados?
Métrica asociada	M-TRAIN-08: Post-Incident Training Rate (%); M-TRAIN-09: Effectiveness (% reduction in future incidents)
Normativa	NIS2 Art. 21.2(g): formación continua y mejora; GDPR Art. 32
Cómo contribuye	Demuestra ciclo de mejora continua y aprovechamiento de incidentes como oportunidad de aprendizaje
Normativa secundaria	ISO 27001 (Annex A.7.3)
Evidencias técnicas	Plan de capacitación post-incidente; evidencia de ejecución
Umbral cumplimiento	Mínimo 80% de afectados reciben formación; idealmente dentro de 7 días post-incidente

TABLA 9: RESUMEN DE MAPEO

Dominio	# Preguntas	Artículos NIS2 Clave	Artículos CRA Clave	Normativa Secundaria
GOV	4	Art. 20, 21	Annex I (gov)	ENS, DORA
DES	3	Art. 21.2(a)	Annex I (design), Art. 10	GDPR Art. 25
IMP	4	Art. 21.2(a)(g)	Annex I (dev)	ISO 27001, DORA
VER	4	Art. 21, 23	Annex I (testing)	CIS Controls
OPS	4	Art. 21.2(b)(c), 23	Art. 10 (remediation)	DORA, ISO 27001
VULN	3	Art. 21.2(a)(d)	Art. 10, Annex I	NIST CSF
SIEM	3	Art. 21.2(b), 23	Annex I (monitoring)	ENS, DORA
TRAIN	4	Art. 21.2(g)	Annex I (training)	GDPR Art. 32, ISO 27001
TOTAL	29	Art. 20, 21, 23	Art. 4, 10, Annex I	GDPR, ENS, DORA, NIST, ISO

CÓMO USAR ESTE DOCUMENTO

- Al diseñar encuesta: Cada pregunta Q-DOMINIO-N puede ser desglosada en ítems específicos de cuestionario, manteniendo referencia al Q-ID.
- Al analizar: Agrupar respuestas por pregunta → calcular métrica → enlazar a artículos normativos.
- Al reportar:
- "Pregunta Q-OPS-1 (MTTD) responde a NIS2 Art. 21.2(b)(c) y DORA Art. 16"
- Resultado: MTTD promedio = 12h (Incumplimiento del objetivo <4h)
- Acciones: Invertir en SIEM, mejorar detección
- Al auditar: Auditor puede verificar pregunta por pregunta que cada área cumpla los artículos normativos.